

21EIE552T – CYBERSECURITY IN INDUSTRIAL AUTOMATION

Dr.G.Y.Rajaa Vikhram
Assistant Professor/EIE
SRMIST

Course Learning Rationale (CLR):	The purpose of learning this course is to:
CLR-1 :	<i>Introduce the basic knowledge in industrial automation and control systems</i>
CLR-2 :	<i>Know the basic concepts of information system security for industrial control systems</i>
CLR-3 :	<i>Understand the difference between IACS and IT paradigms</i>
CLR-4 :	<i>Impart the adequate information about risk management for IACS</i>
CLR-5 :	<i>Introduce the security methodologies and approaches for IACS</i>
CLR-6 :	<i>Understand the need of cybersecurity for different industrial applications</i>

Course Outcomes (CO):	At the end of this course, learners will be able to:
CO-1 :	Describe the basic concepts of industrial automation and control systems
CO-2 :	Illustrate any application with add-on security features in industrial control systems
CO-3 :	Select the software with IT paradigms for IACS
CO-4 :	Analyze the risk management approach for IACS
CO-5 :	Examine the security methodologies for industrial systems
CO-6 :	Design cybersecurity resilient algorithm for selective applications

IACS Culture versus IT Paradigms
12
Differences in Culture, Philosophy, and Requirements
Comparison between IT and IACS Issues
Considerations in Adapting IT Security methods to IACS
Threats and Motivations for Attackers
Threat Sources
IT and IACS comparisons from a Standards Perspective
Tutorial: 1 – OT vs IT layer
Technological Trends
Smart Grid and its trends
Smart Grid Protocols

Mapping of Emerging Technology
Example Automation System
Bulk Generation
Tutorial: 2 – OT security
Transmission Domain
Distribution Domain
Operations Domain
Service Provider Domain
Markets Domain
Customer Domain
Tutorial: 3 – IT security

Industrial Automation and Control System Culture versus IT Paradigms

Some of the basic principles of information system security were presented in [Chapter 2](#) as a prelude to selectively and properly applying them to securing industrial automation and control systems. As a prerequisite to this adaptation, it is important to examine the differences in culture, requirements, and operational issues between automation and control systems and IT systems. Critical areas that have to be addressed include safety, real-time demands, maintenance, productivity, training, and personnel mindsets. These topics and related subject areas are discussed in this chapter to help the reader better understand how to apply security principles to automation and control systems without negatively impacting their primary mission and in full acknowledgement of their special requirements.

Differences in Culture, Philosophy, and Requirements

The major advances in securing computer systems and networks have come through the information system technology route, with origins in computer science and software engineering. The principal players are IT system administrators, systems analysts, database administrators, software engineers, network administrators, CIOs (chief information officers), and so on. On the other hand, a large number of the personnel populating the industrial automation and control system field come from engineering backgrounds, with training in such areas as electrical engineering, chemical engineering, mechanical engineering, systems engineering, and control engineering.

The motivation, requirements, and focus of each of the groups are, in many instances, largely divergent, with some overlapping common areas. For example, software quality and process improvement methods widely used in the IT environment are often foreign to control engineers and in fact may be viewed as cumbersome in implementing SCADA and process control algorithms. In addition, the performance of a process in a plant is critical, and inadequate performance in production areas can result in huge financial losses, equipment damage, and personnel injuries. These severe consequences of operational errors are not usually a common occurrence in IT facilities. Similarly, safety is a critical concern in a production environment, and control system malfunctions can result in fires or explosions in some instances. Thus, in a production environment, safety and performance usually take precedence over information security, which is not the case in an information system.

Some of the major differences between IT and industrial automation and control system requirements are listed in [Table 3-1](#).

Table 3-1. Comparison Between IT and Industrial Control and Automation Systems Issues

Issue	IT systems	Industrial automation and control systems
Application of encryption	Advanced encryption systems used.	Encryption used sometimes or not at all. Delays caused by encryption software are a consideration.
Degree of employment of patch management	Implementation of software patches performed routinely under formal procedures.	Installation of software patches usually done infrequently, with deliberation, and with involvement of vendors. The impact of software patches should be tested off-line to ensure no harmful effects are introduced into the process or plant. In some instances, adding patches can produce some dangerous consequences.
Degree of vulnerability testing	Penetration testing by ethical hackers is widely used to	Penetration testing must be conducted sparingly and at appropriate times in

	expose vulnerabilities.	order not to inadvertently cause malfunctions in monitoring and control systems.
Employment and impact of security software	Antivirus software effective and commonly used to scan for malware.	Antivirus software can be used but issues, such as delays due to scanning and processing and lack of spare computing cycles, might cause problems in plant systems.
Employment of change management	Change management used extensively to document and confirm system changes.	Change management employed inconsistently and sporadically in many organizations. Changes might also result in hazardous situations.
Impact of equipment upgrades	Equipment modifications, upgrades, and replacements occur almost continuously in various parts of organizations.	Many legacy systems in use with few changes over periods of many years.
Level of security awareness training	Awareness training actively conducted in accordance with security policy.	Security awareness training conducted sporadically and inconsistently in many cases.

Tolerance to data loss	Recovery from data loss can usually be accomplished from backups without severe consequences in most situations.	Loss of data can result in loss of product, unsafe conditions, and disruption of plant operations.
Tolerance to loss of availability	Recovery follows standard procedures, and unless availability is lost for extended periods of time, effects are not disastrous. However, availability is critical and can affect mission objectives.	Systems should be designed with resiliency; however many are not, particularly legacy systems. Loss of availability can have serious consequences, including safety of personnel and equipment.
Tolerance to loss of confidentiality	Depending on the data involved, the consequences might be minimal or extremely harmful, such as the loss of trade secrets, personnel data, credit card numbers, and health information.	Consequences not usually severe.
Tolerance to loss of integrity	Consequences can range from minimal to extremely harmful if critical data has	Consequences can be very severe because, in many instances, critical decisions are made based on data assumed to be correct.

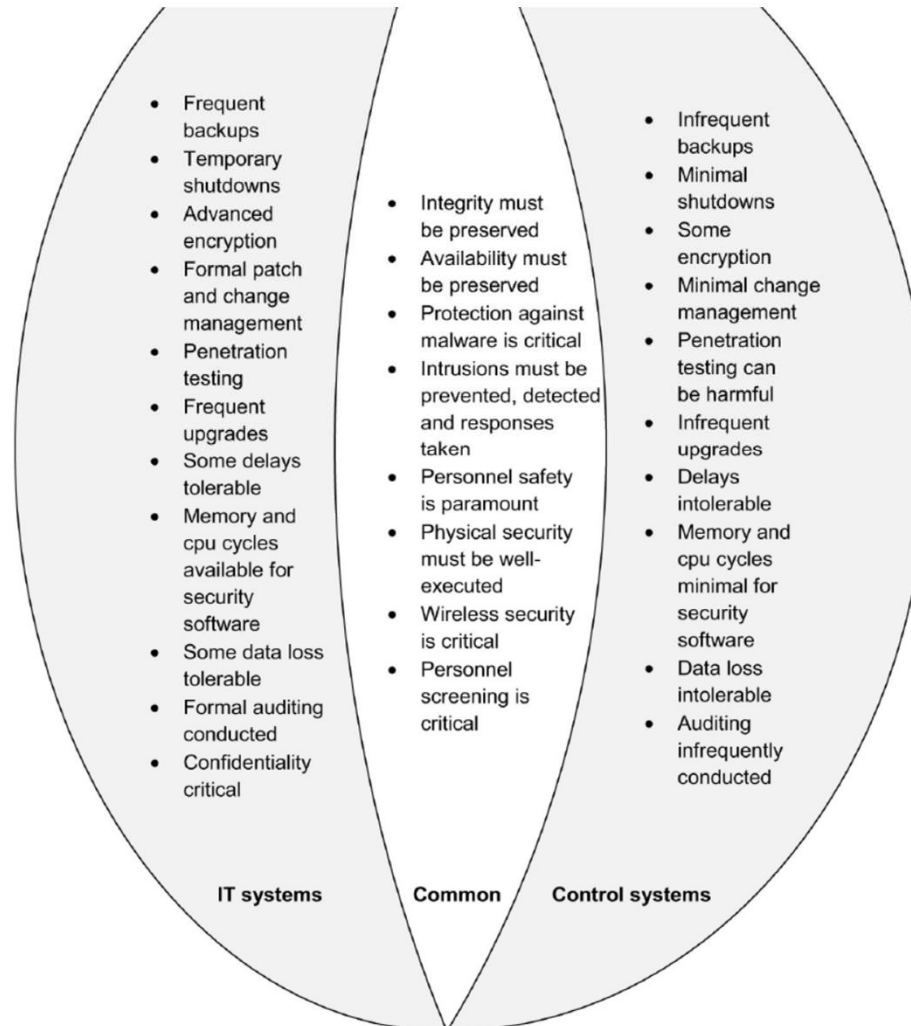
	been altered and is acted upon as being valid.	
Tolerance to system delays	In most cases, delays might be considered a nuisance, but can be tolerated.	In situations where critical control decisions are based on deterministic response times, delays might result in serious or dangerous consequences.
Use of auditing	Based on organizational policies, internal and external audits are normally conducted and provide detective controls for breaches of information system security.	Audits of systems' security posture conducted irregularly and are a function of the particular organization and regulatory requirements.
System performance	Performance can be suboptimal at times.	Proper performance is critical.
Safety	Safety is critical, particularly that of personnel.	Safety is critical, particularly that of personnel.

Figure 3-1 summarizes the important issues listed in Table 3-1 and emphasizes some of the common areas between IT and automation and control systems.

The lesson to be learned from these comparisons is that traditional information system security knowledge and methods provide a solid basis for addressing industrial automation and control system security, albeit with deliberate, appropriate, and intelligent modifications required to address the unique characteristics of automation and control systems.

One important starting point in incorporating these modifications is education. In general, most universities and certification programs addressing computer and network security have been heavily focused on IT security. Automation and control systems, which are typically sitting on isolated networks and are relatively few in number compared to IT systems, have not been considered to be interesting targets. With the advent of the terrorism threat, this situation is no longer the case. In addition, SCADA and plant process control systems are now being connected to large networks and the Internet.

Figure 3-1. IT and automation and control system issue comparisons



The Certified Information System Security Professional (CISSP) and related certifications do not address the security of industrial automation and control systems. Organizations, such as ISA, have addressed this problem and are filling a critical need. NIST has generated special publications that directly address industrial automation and control systems. However, it is important that security training related to the control of production lines, industrial processes, electrical transmission and distribution, pipelines, chemical plants, and so on moves to the fore in universities, technical institutes, and certification organizations.

To understand how to adapt IT security methods to industrial automation and control system security, threats to the latter have to be identified and understood. One impediment to full disclosure of threats realized is the fact that a majority of affected facilities are privately owned, and these organizations are reluctant to publicize security breaches that could negatively affect their reputation and value.

Organizations also need incentives to invest in upgrading their automation and control infrastructure. Many existing installations have been in place for ten or twenty years, and investments in security have to compete with other compelling initiatives in an organization.

Considerations in Adapting IT Security Methods to Industrial Automation and Control Systems

In order to secure industrial automation and control systems (IACS), there are specific issues that have to be addressed that take into account the differences between IT systems and IACS. These issues include the following:

- Accountability, authorization, and computer forensics have not matured and have not been implemented widely in IACS as compared to IT systems.
- Ethernet to serial line paths provide a means of injecting malicious commands into a control network.
- Excessive checking, encryption, monitoring, and so on can interfere with the deterministic nature of process control systems.

- In many IACS environments, control engineers have multiple responsibilities that, in many instances, violate the security principle of separation of duties.
- Installing patches and upgrades in process control systems can lead to serious and sometimes dangerous situations in production facilities.
- Life cycle design disciplines common in the IT field are not widely used in industrial automation and control systems.

- Maintenance hooks and trap doors installed in automation and control systems for remote maintenance can be easy entry points to modify critical software and firmware with negative consequences.
- Many IACS vendors combine safety mechanisms with security mechanisms, leading to single points of failure and less resiliency than separating these two functions logically and physically.
- Many manufacturing facilities and SCADA installations house legacy systems with outdated technology, minimal memory and computing power, and little thought to security.
- Port scanning of automation and control systems can result in blockages and lack of system availability.

- Remote access into automation and control systems via older modems or newer wireless devices poses a serious threat to security.
- There is a trend to apply protocols used for IT systems to industrial control and automation systems because of their wide availability, their lower cost, and the existence of trained personnel. However, these protocols, in most instances, were not designed for deterministic process control systems and also are vulnerable to many existing attacks.
- There is heavy reliance on suppliers, who provide modified software and hardware for IACS, resulting in nonstandard implementations that are difficult to maintain without support from these suppliers.
- Weak authentication mechanisms in many SCADA systems and networked plant control systems leave them vulnerable to attack.

A variety of additional items must be considered when discussing comparisons between IT and industrial automation and control systems. The concepts related to risk management and the means to protect industrial automation and control systems will be discussed in detail in [Chapters 5 and 6](#), respectively. However, it is important to now examine some related critical subject areas to provide a basis for developing more specific security solutions.

Threats

Threats to IT and industrial automation and control systems come from different sources, with different motivations. It is important to understand these threat sources and their characteristics in order to counter any malicious activities on their part. NIST SP 800-30¹ summarizes the various types of threat sources and some of their driving factors as shown in [Table 3-2](#). [Table 3-3](#), also from NIST SP 800-30, provides a listing of some general threat sources, including environmental ones, which can also cause disruptions to industrial automation and control systems.

The categories of terrorists, industrial espionage, and insiders are of particular interest in connection with industrial automation and control systems. Traditionally, insider threats have been considered one of the most dangerous because they give insiders the ability to bypass protective measures. However, external threats are increasing and are also of grave concern, particularly relating to our nation's critical infrastructure and resource processing plants. In addition, threats to automation systems can materialize from environmental and structural sources as illustrated in the next section.

Sensitivity of Industrial Automation and Control Systems to Upgrades and Modifications

One area that is not usually considered when discussing the relative sensitivities of IT systems and industrial automation and control systems are the effects of equipment upgrades and modifications. A particularly relevant example concerns the consequences of converting analog controls to digital controls. Digital systems transfer information via pulses, which inherently generate high frequency electromagnetic radiation that can interfere with control system operations. An article in the journal *Interference Technology*² describes the electromagnetic radiation emission environment in a nuclear plant that was being changed from analog to digital controls. The authors obtained measurement data in the range of 100 Hz to 6 GHz in instances before and after the conversion.

Table 3-2. Threats and Motivations for Attackers

Threat-Source	Motivation	Threat Actions
Hacker, cracker	Challenge Ego Rebellion	• Hacking • Social engineering • System intrusion, break-ins • Unauthorized system access
Computer criminal	Destruction of information Illegal information disclosure Monetary gain Unauthorized data alteration	• Computer crime (e.g., cyber stalking) • Fraudulent act (e.g., replay, impersonation, interception) • Information bribery • Spoofing • System intrusion
Terrorist	Blackmail Destruction Exploitation Revenge	• Bomb/Terrorism • Information warfare • System attack (e.g., distributed denial of service) • System penetration • System tampering

Industrial espionage (companies, foreign governments, other government interests)	Competitive advantage Economic espionage	• Economic exploitation • Information theft • Intrusion on personal privacy • Social engineering • System penetration • Unauthorized system access (access to classified, proprietary, and/or technology-related information)
Insiders (poorly trained, disgruntled, malicious, negligent, dishonest, or terminated employees)	Curiosity Ego Intelligence Monetary gain Revenge Unintentional errors and omissions (e.g., data entry error, programming error)	• Assault on an employee • Blackmail • Browsing of proprietary information • Computer abuse • Fraud and theft • Information bribery • Input of falsified, computed data • Interception • Malicious code (e.g., virus, logic bomb, Trojan horse) • Sale of personal information • System bugs • System intrusion • System sabotage • Unauthorized system access

[Source: NIST SP 800-30, Revision 1, *Guide for Conducting Risk Assessments*, September 2011.]

The testing followed guidelines in U.S. Nuclear Regulatory Commission Regulatory Guide, NUREG 1.180³ and Electric Power Research Institute (EPRI) document TR-102023-2004⁴. In the tests, antennas were installed next to three cabinets housing control electronics, and radiation emission measurements were taken from the analog and digital control installations. Some of the results obtained are summarized in [Table 3-4](#), showing frequencies at which peak amplitudes occur at antennas 1 and 2.

Table 3-3. Listing of General Threat Sources

Type of Threat Source	Description	Characteristics
ADVERSARIAL - Individual - Outsider - Insider - Trusted Insider - Privileged Insider - Group - Ad hoc - Established - Organization - Nation-State	Individuals, groups, organizations, or states that seek to exploit the organization's dependence on cyber resources (i.e., information in electronic form, information and communications technologies, and the communications and information-handling capabilities provided by those technologies).	Capability, Intent, Targeting
ACCIDENTAL - Ordinary User - Privileged User/Administrator	Erroneous actions taken by individuals in the course of executing their everyday responsibilities.	Range of effects

STRUCTURAL - IT Equipment - Storage - Processing - Communications - Display - Sensor - Controller - Environmental Controls - Temperature/Humidity Controls - Power Supply	Failures of equipment, environmental controls, or software due to aging, resource depletion, or other circumstances which exceed expected operating parameters.	Range of effects
- Software - Operating System - Networking - General-Purpose Application - Mission-Specific Application		

ENVIRONMENTAL - Natural or man-made disaster - Fire - Flood/Tsunami - Windstorm/Tornado - Hurricane - Earthquake - Bombing - Overrun - Unusual Natural Event (e.g., sunspots) - Infrastructure Failure/Outage - Telecommunications - Electrical Power	Natural disasters and failures of critical infrastructures on which the organization depends, but which are outside the control of the organization. Note: Natural and man-made disasters can also be characterized in terms of their severity and/or duration. However, because the threat source and the threat event are strongly identified, severity and duration can be included in the description of the threat event (e.g., Category 5 hurricane causes extensive damage to the facilities housing mission-critical systems, making those systems unavailable for three weeks).	Range of effects
[Source: NIST SP 800-30, Revision 1, <i>Guide for Conducting Risk Assessments</i>, September 2011.]		

Table 3-4. Radiation Emission Measurements

Antenna	Analog measurement		Digital measurement	
	Frequency	Significant peak amplitudes (dBμV/m)	Frequency	Significant peak amplitudes (dBμV/m)
1	1.34 MHz	99.2	468 MHz	71.6
1	928 MHz	76.6	826 MHz	94.5
1			928 MHz	113.5
1			1.35 GHz	49.9
1			1.88 GHz	50.5
1			1.92 GHz	53.4
1			2.41 GHz	76.3
1			2.46 GHz	54.4
1			5.82 GHz	60.6
2	1.04 MHz	99.3	2MHz	84
2	4.55 MHz	88.5	10MHz	80
2			1GHz	109
2			1.17 GHz	48.8
2			1.92 GHz	48.9
2			2.42	57.7
2			5.82 GHz	50.9
[Source: Keebler, P. and Berger, S. "Going from Analog to Digital," <i>Interference Technology</i> , 2011 EMC Directory and Design Guide, 2011.]				

This data is plotted in [Figures 3-2](#) and [3-3](#) for antennas 1 and 2, respectively. Note that the digital electronics generate more peak radiation generally and more at high frequencies compared to the analog equipment. These peak emissions have the potential to interfere with control system signals and cause malfunctions if proper shielding and isolation are not applied.

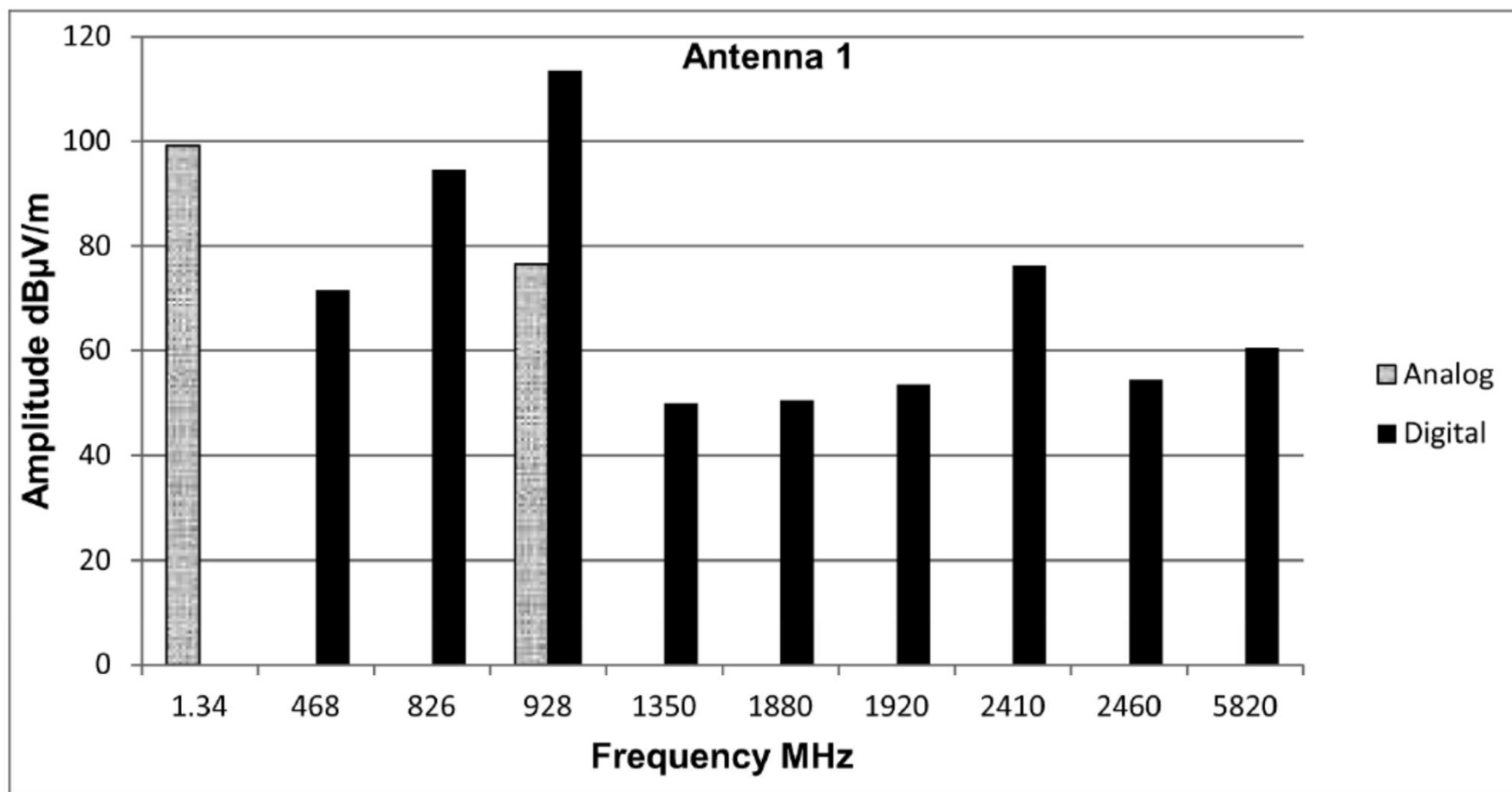


Figure 3-2. Analog and digital radiation emissions received at antenna 1

The sample electromagnetic emanations collected illustrate the necessity to ensure electromagnetic compliance (EMC) when equipment upgrades are made to plant control systems. These actions will serve to protect against interruptions of control systems' operation because of electromagnetic emissions from digital systems.

IT and Industrial Automation and Control Systems Comparisons from a Standards Perspective

Valuable insight into the contrasts and similarities between IT systems security focus areas and those of industrial automation and control systems can be obtained from an example using standards that represent each of the areas. In this example, ISO/IEC 27002, *Code of Practice for Information Security Management*⁵ will be used to represent IT systems security areas of emphasis while ANSI/ISA-99.02.01-2009, *Security for Industrial Automation and Control Systems: Establishing an Industrial Automation and Control Systems Security Program*⁶, will be used to illustrate the major concerns of automation and control system security.

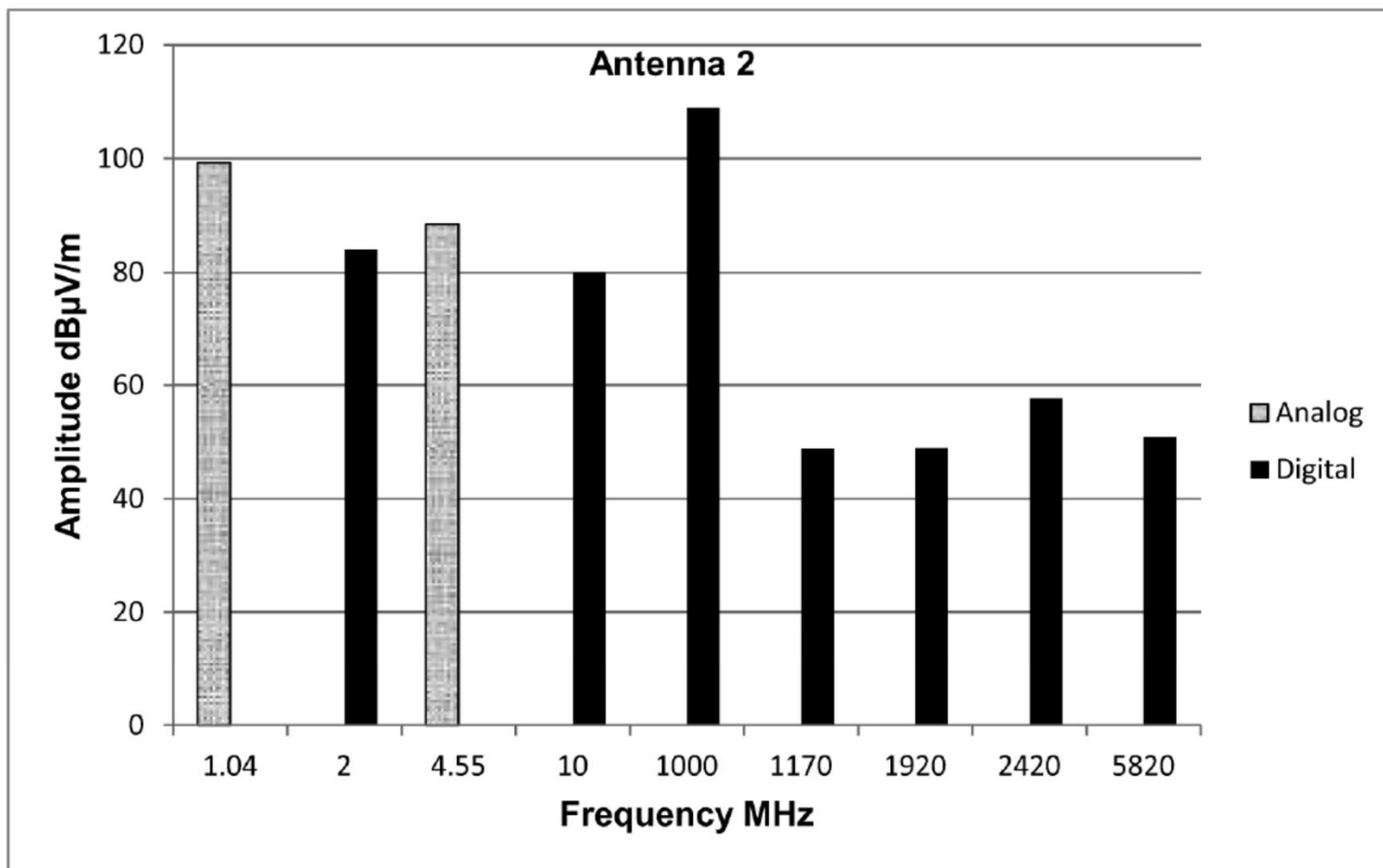


Figure 3-3. Analog and digital radiation emissions received at antenna 2

In each document, there are common areas addressed by both standards and other areas addressed by one and not the other. [Figure 3-4](#) summarizes the main characteristics of each standard and identifies common areas addressed by both as well as topics that are addressed mainly by one document and not the other.

[Figure 3-4](#) shows that topics, such as change management, email security, access control policies, digital signatures, compliance, and business continuity planning are among the areas considered critical for IT systems that are not emphasized in automation and control system standards. Conversely, for automation and control systems, the significant domains not covered include security architecture analysis, quantitative and qualitative analysis, information security management, and information security testing. Areas of common emphasis include information security policy, risk assessment, training, media physical security, remote access, event logging, and protection against malware.

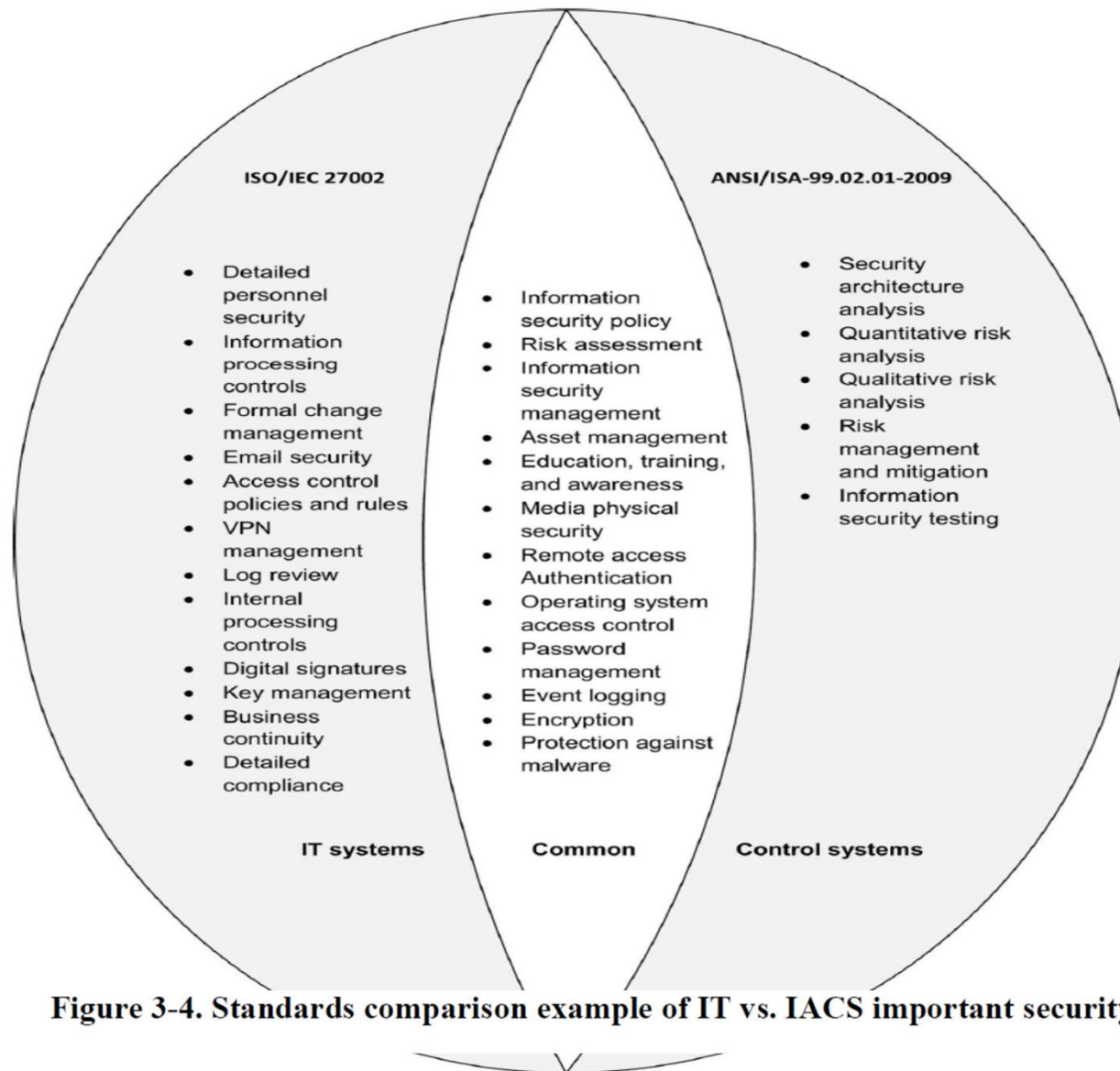


Figure 3-4. Standards comparison example of IT vs. IACS important security areas

Summary

Understanding the requirements of industrial automation and control systems security and how they relate to IT systems supports a mapping of these requirements onto the emerging technologies being employed in the control of production processes as well as the critical infrastructure (represented primarily by the electrical generation and distribution grid). The advances in capability and sophistication of industrial automation and control systems require a tailored approach to security. Some of the factors pushing the industrial automation and control systems security envelope include:

- The Smart Grid
- Advanced cryptography and key management applications
- Advanced PLCs and PACs
- Advanced protective relaying
- Advanced wireless networks
- Alarm processing
- Availability of real-time energy information
- Multisphere security among IT, transportation, and power systems
- Redundancy in networks, equipment, and sensors
- Fiber communication
- Use of GPS tracking

Part – 2 will investigate the technical evolution taking place in elements of the critical infrastructure and in key production facilities to identify the important risk factors and areas of maximum potential impact in the event of an attack.

Part – 2

The Continuing Technological Evolution Affecting the Industrial Automation and Control Systems

Chapter 3 presented the important differences between IT systems and industrial automation and control systems, along with some areas that are common to both of them. However, it is important to recognize that these differences are based on elements in both technologies that are constantly evolving. Thus, in order to truly understand and safeguard automation and control systems, these technology drivers and their potential effects on the components of the critical infrastructure have to be identified and examined. **Part – 2** investigates these areas and focuses on technological issues that relate directly to the security posture of the critical infrastructure, using the Smart Grid as an example.

Important Technological Trends

At any point in time, as technological advances occur and the technologies are adopted, related issues often appear. In this chapter, some of the major technological trends and associated concerns that directly and indirectly affect (or will affect) the industrial automation and control system landscape are examined. Then, the Smart Grid initiative will be explored relative to these technological developments as an example in the automation and control systems field.

Some of the emerging technological trends and associated concerns that will have a significant impact on both business and industry are home area networks, energy storage, analytics, cloud computing, privacy, social networks, mobile technology, and interoperability.

Home Area Networks

An increasing number of homes have a home area network (HAN) to some extent. The most common implementation is connecting devices, such as PCs, printers, laptops, tablet devices, Internet telephones, smart phones, and game computers. Additional items that are being connected and that will be more commonly connected in the future are digital video recorders, TV sets, and network attached storage (NAS) devices.

Relative to the Smart Grid, home area networks are being viewed as important network elements to connect to smart meters. It is anticipated that the home area network will host smart thermostat controls, user information displays, and interfaces to remotely control such items as appliances, lighting, and security systems. With this capability, a smart meter could communicate with appliances over the home area network to reduce energy consumption during periods of peak demand while also supplying information to customers, service providers, suppliers, and utilities. Customers could use this information to alter usage patterns and reduce energy costs.

Energy Storage

Energy storage device technology is advancing because of the needs of hybrid and electric vehicles. In addition, finding a means to capture and store intermittent, renewable energy is driving such technologies as “super” batteries and ultracapacitors as well as other devices. The advent of the Smart Grid has put a new emphasis on efficient energy storage methods that can be applied at various points in the Grid to supplement conventional electricity generation methods.

Analytics

Analytics is the application of data mining and analysis to large amounts of data for the purposes of discovering knowledge and making intelligent predictions and decisions. Because large volumes of data are being generated and captured in very short amounts of time in automation and

control systems, being able to analyze this data and make sound decisions based on this analysis is becoming increasingly important and necessary. A typical example is using analytic tools to visualize data within databases, networks, and applications and to make critical decisions in real time. A related issue is the ability to meaningfully display acquired information and share it among colleagues to support collaboration and innovative decision making.

Traditionally, analytics has been applied in electrical power systems for condition monitoring of high voltage electrical equipment. However, analytics holds promise for more sophisticated support of industrial automation and control systems to support rapid decision making and to provide an instinctively understandable visualization of critical information. Specifically, data collected on the Smart Grid through wireless, optical fiber, and other communication means can provide data on the health of Grid components, such as transformers, as well as voltage monitoring and energy consumption information. This data can be used to identify areas of potential failure and to initiate corrective action before actual outages occur.

Analytics can also be applied to secure industrial automation and control systems in the form of cyber analytics. In cyber analytics, data from a variety of sources can be analyzed in real time or near real time to perform predictive modeling and thereby support physical, logical, and administrative security.

Cloud Computing

The cloud computing paradigm is being embraced by many organizations, and this will affect how data is collected, stored, and processed in these organizations, including in automation and control systems. NIST¹ defines cloud computing as:

A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This

cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models.

The NIST document defines the essential characteristics of cloud computing as:

On-demand self-service. A consumer can unilaterally provision computing capabilities, such as server time and network storage, as needed automatically without human interaction with each service's provider.

Broad network access. Capabilities are available over the network and accessed through standard mechanisms that promote use by heterogeneous thin or thick client platforms (e.g., mobile phones, laptops, and PDAs).

Resource pooling. The provider's computing resources are pooled to serve multiple consumers, using a multitenant model, with different physical and virtual resources dynamically assigned and reassigned according to consumer demand. There is a sense of location independence in that the consumer generally has no control over or knowledge about the exact location of the provided resources but may be able to specify location at a higher level of abstraction (e.g., country, state, or data center). Examples of resources include storage, processing, memory, network bandwidth, and virtual machines.

Rapid elasticity. Capabilities can be rapidly and elastically provisioned, in some cases automatically, to quickly scale out, and rapidly released to quickly scale in. To the consumer, the capabilities available for provisioning often appear to be unlimited and can be purchased in any quantity at any time.

Measured service. Cloud systems automatically control and optimize resource use by leveraging a metering capability at some level of abstraction appropriate to the type of service (e.g., storage, processing, bandwidth, and active user accounts). Resource usage can be monitored, controlled, and reported, providing transparency for both the provider and consumer of the utilized service.

The three NIST cloud service models are:

Cloud Software as a Service (SaaS). The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure.

Cloud Platform as a Service (PaaS). The capability provided to the consumer is to deploy onto the cloud infrastructure consumer-created or acquired applications created using programming languages and tools supported by the provider.

Cloud Infrastructure as a Service (IaaS). The capability provided to the consumer is to provision processing, storage, networks, and other fundamental computing resources where the consumer is able to deploy and run arbitrary software, which can include operating systems and applications.

NIST defines the cloud deployment models as:

Private cloud. The cloud infrastructure is operated solely for an organization. It may be managed by the organization or a third party and may exist on premises or off premises.

Community cloud. The cloud infrastructure is shared by several organizations and supports a specific community that has shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be managed by the organizations or a third party and may exist on premises or off premises.

Public cloud. The cloud infrastructure is made available to the general public or a large industry group and is owned by an organization selling cloud services.

Hybrid cloud. The cloud infrastructure is a composition of two or more clouds (private, community, or public) that remain unique entities but are bound together by standardized or proprietary technology that enables data and application portability.

Cloud computing emphasizes service and can result in lower costs, agility, and the ease of integration of business and industrial processes. It can also increase availability through the distribution of capabilities to areas both inside and outside of the organization. Availability can also be enhanced by the cloud's ability to automatically manage and transport virtual applications dynamically. This approach supports automatic failover, provisioning to adapt to load demands, enforcement of security policies, and monitoring of security violations.

The cloud can also provide exceptional resources in the implementation of analytics solutions.

Privacy

Privacy is becoming more and more important in the conduct of business and computer-related activities. Special precautions have to be taken to protect personally identifiable information (PII) in all types of environments to avoid violation of regulatory and compliance requirements, such as HIPAA. PII is information that can be used to identify an individual and discover sensitive information about that individual. It is imperative that the management of an organization ensures that proper and adequate controls are in place to protect this sensitive information. These controls must include robust identification and authentication mechanisms to protect both individuals and physical equipment. Disclosure of PII such as a user's password, social security number, address, and health situation can be used to compromise the person and eventually gain access to critical organizational information and equipment. Threats to computer systems continually evolve and are becoming more sophisticated. Intentional or unintentional employee actions can bypass protection mechanisms and cause serious physical and financial damage and loss or compromise of sensitive information.

An organization should have privacy policies in place that are a statement of management intent and commitment to protect PII. A privacy policy

usually addresses what information is collected, email rules, what information is shared with partners, how information is protected, disclosure rules, and authentication mechanisms.

Most privacy policies embody the following five basic principles:

- Access – Individuals should be able to review and correct their PII.
- Choice – Individuals should have the choice to opt out or opt in on permitting the disclosure of their PII to other entities.
- Enforcement – Privacy rules should be enforced.
- Notice – Individuals should be kept informed of the disclosure and use of PII.
- Security – Unauthorized disclosure of PII should not occur.

The European Union (EU) has codified privacy principles that apply to their citizens. These principles are:

- Data should be collected in accordance with the law.
- Data should be used only for the purposes for which it was collected, and it should be used only for a reasonable period of time.
- Individuals are entitled to receive a report on the information that is held about them.
- Individuals have the right to correct errors contained in their personal data.
- Information collected about an individual cannot be disclosed to other organizations or individuals unless authorized by law or by consent of the individual.
- Records kept on an individual should be accurate and up to date.
- Transmission of personal information to locations where equivalent personal data protection cannot be assured is prohibited.

Because in the Smart Grid paradigm personal data will be collected, transmitted, and stored, privacy protection should be inherent in the Grid.

The principles expounded in the previous paragraphs can serve as guidance in privacy implementations for the Smart Grid.

As discussed earlier in this chapter, cyber analytics can be useful in determining patterns and threat vectors from large and diverse sources of data to predict possible future attacks or compromises of PII.

Social Networks

Social networks are becoming widely used by individuals in all walks of life. According to Facebook statistics², there are more than 500 million active users who spend over 700 billion minutes per month on Facebook. Social sites, such as Facebook, which many consider hobbies, can be sources of vital information and serve as platforms for collaboration, innovation, and rapid transactions. Incorporating such platforms and media into a corporate environment can provide benefits, such as providing business intelligence, conducting training, and enhancing communications among colleagues, customers, and partners. On the other hand, social networks can be points of vulnerability for attackers and serve as avenues for the compromise of sensitive information. Participation in social networks at all levels of an organization can impact the security and privacy of the organization by providing information that can lead to the disclosure of proprietary data.

Mobile Technology

Interactivity is becoming the norm in dealing with digital devices and systems. Users can communicate with systems through social media, touchscreens, and mobile devices. Accessing data and controlling automation and control systems easily through iPad-like interfaces from a variety of physical locations offer both opportunities and concerns. The proliferation of 4G WiMAX will make remote communications from mobile devices more common and allow messaging and controls to be available to a variety of personnel and applications. Transactions on these networks will have to be managed, and policies redesigned, to accommodate such communications.

Interoperability

Interoperability is the ability of an entity to exchange data with another entity. In the computer realm, this data exchange can consist of software applications communicating with each other through common protocols and file formats. With the advent of technologies such as cloud computing and mobile platforms, it is important not to tie applications to specific types of platforms and not to discourage moving applications among different computers, storage, and networks.

Historically, industrial automation and control systems were developed on hardware and software modified by vendors for targeted applications and could not be ported to other platforms.

In implementing advanced industrial automation and control systems for programs, such as the Smart Grid, it is critical that hardware and software are interoperable and are verified for interoperability through some of the following means:

- Use independent testing groups to evaluate interoperability of software and hardware products from different sources
- Statistically test samplings of combinations of applications for interoperability and project the probability of the other similar combinations being interoperable
- Test all software items against a standard reference to determine interoperability
- Test hardware items against applicable standards to ensure interoperability

The security of interoperable software components poses a different set of issues. The question to be answered is how to determine the security posture of application software comprised of software components whose security has been evaluated. It is not always the case that the features and characteristics of the resultant composite model reflect the security characteristics of the component software elements. These issues are explored in detail in a paper by Oladimeji and Chung from the University of Texas³. In the paper, the authors demonstrate that using secure software components to build a large system does not always guarantee the security of the large system. They also present an approach that can be used to ensure that the security requirements of the composite system are fulfilled when using secure components or to show that some components might not satisfy the security specifications of the composite system.

The Smart Grid and Technological Trends

It is important to identify the effects of technological developments on industrial automation and control systems. Technology advances have been incorporated into the elements of the critical infrastructure and, in doing so, have increased performance and efficiency. Networks that were once isolated are now interconnected and, in many instances, manage data from a variety of organizations. A natural progression of this technological evolution is to use advanced automation and networking methods to optimize system operations. However, the improvements in performance obtained by these enhancements have to be considered in light of the impact of the new technologies on safety, security, cost, and long-term consequences. To provide an illustration of these issues, the Smart Grid technologies will be overlaid with the technological trends described in the first part of this chapter. The following discussion is not meant to be an exhaustive exploration of the Smart Grid, but is presented to provide enough detailed information to serve as a basis for exploring the consequences of technological evolution and applications on an advanced automation and control system.

In the NIST document *Framework and Roadmap for Smart Grid Interoperability Standards*⁴, the Smart Grid is characterized as “adding and integrating many varieties of digital computing and communication technologies and services with the power-delivery infrastructure. Bidirectional flows of energy and two-way communication and control capabilities will enable an array of new functionalities and applications that go well beyond ‘smart’ meters for homes and businesses.” The NIST document also cites the following distinguishing characteristics of the Smart Grid as:

- Increased use of digital information and controls technology to improve the reliability, security, and efficiency of the electric grid
- Dynamic optimization of grid operations and resources, with full cybersecurity
- Deployment and integration of distributed resources and generation, including renewable resources
- Development and incorporation of demand response, demand-side resources, and energy efficiency resources
- Deployment of “smart” technologies for metering, communications concerning grid operations and status, and distribution automation
- Integration of “smart” appliances and consumer devices

- Deployment and integration of advanced electricity storage and peak-shaving technologies, including plug-in electric and hybrid electric vehicles and thermal-storage air conditioning. An example of peak shaving would be a hybrid electric vehicle sending power back to the grid when demand is high.
- Provision to consumers of timely information and control options
- Development of standards for communication and interoperability of appliances and equipment connected to the electric grid, including the infrastructure serving the grid
- Identification and lowering of unreasonable or unnecessary barriers to the adoption of Smart Grid technologies, practices, and services

In summary, the idea of the Smart Grid is to automate the electric power system by providing the ability to monitor and optimize operations across the grid from bulk generation to the consumer through two-way transmission of electricity and information.

Some of the benefits of the Smart Grid are put forth as:

- Built-in cybersecurity
- Higher grid resiliency
- Higher power quality
- Improved energy delivery efficiency
- Improved generation efficiency
- Reduced emissions and pollutants
- Reduced operating costs

With the increased interconnectivity and linking of Smart Grid networks, there are increased risks. These risks are summarized as follows from the NIST Guidelines for Smart Grid Cybersecurity⁵:

- Increasing the complexity of the grid could introduce vulnerabilities and increase exposure to potential attackers and unintentional errors.
- Interconnected networks can introduce common vulnerabilities.
- Increasing vulnerabilities to communication disruptions and the introduction of malicious software/firmware or compromised hardware could result in denial of service (DoS) or other malicious attacks.
- Increased number of entry points and paths are available for potential adversaries to exploit.
- Interconnected systems can increase the amount of private information exposed and increase the risk when data is aggregated.
- Expansion of the amount of data that will be collected can lead to the potential for compromise of data confidentiality, including the breach of customer privacy.

Relative to the C-I-A triad of confidentiality, integrity, and availability, availability will be the most important of the three principles in the Smart Grid environment. Data integrity is also important while confidentiality ranks third in the list, in general. For confidentiality, encryption keys will be used in the Smart Grid, and management of the large numbers of keys involved will be an important task.

NIST has developed a framework for the Smart Grid as shown in [Figure 4-1](#).

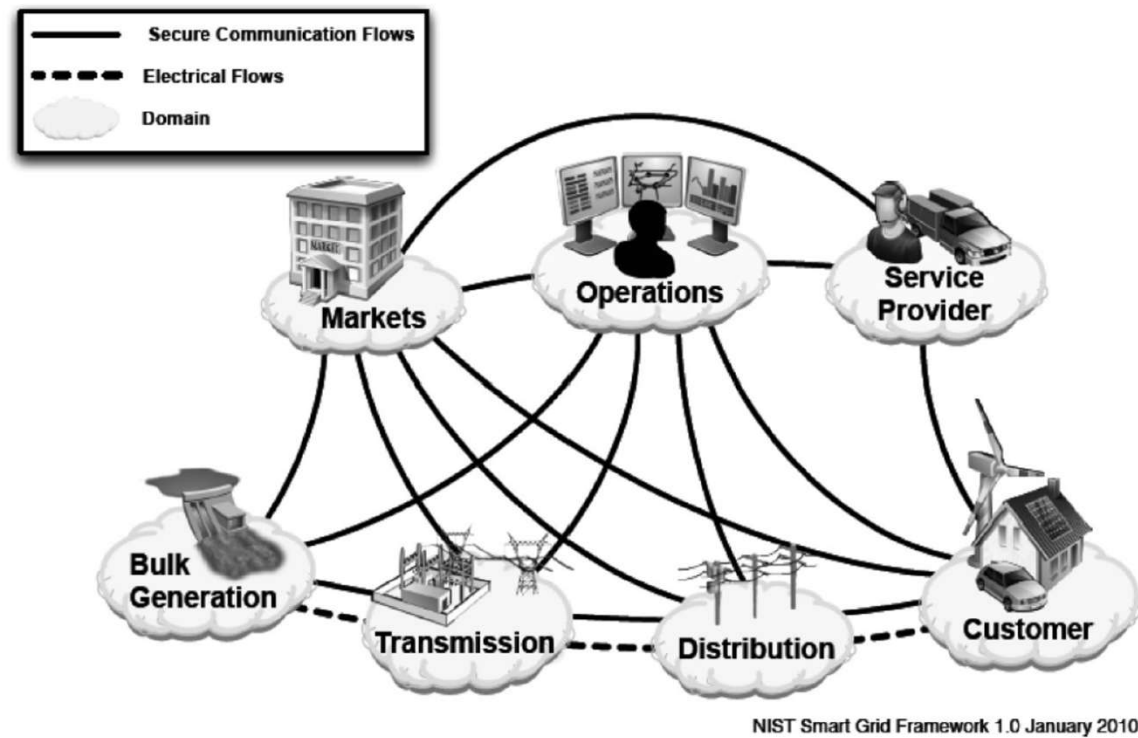


Figure 4-1. Smart Grid interactions and electrical flow

In [Figure 4-1](#), customers have the historical role of consuming electricity. However, in the Smart Grid architecture of [Figure 4-1](#), the customer can also be a source of electricity that can be generated and stored at the customer's site. Operations are responsible for managing the movement of electricity in the Smart Grid, and markets refer to the markets for selling and buying electricity. Bulk generation produces and stores electricity and uses transmission systems to move the electricity over large distances. Then the electricity is taken from the Transmission system and provided to the customer through the distribution system. A summary of the roles of these domains is given in the following sections.

Bulk Generation

The bulk generation domain principally connects to and communicates with the transmission and operations domains, but it also communicates with some of the other domains as shown in [Figure 4-1](#). Bulk generation provides energy generated from sources such as coal, gas, water from dams, nuclear reactions, geothermal, the sun, and wind. In the Smart Grid environment, bulk generation must also be able to store energy from sources that are not continuously available.

SCADA systems are employed in the bulk generation domain to control and measure its subsystems and exchange data with the operations domain.

The Transmission Domain

The transmission domain delivers electrical power from the bulk generation domain to the distribution domain and balances the required electrical load between these two entities. It also provides energy storage capabilities. There is close coordination between the transmission domain and the operations domain. The transmission domain incorporates transformer substations that step up the voltage for transmission and then step-down the voltage for the distribution domain.

Additional energy supplies required by the transmission domain are obtained through the marketing domain. Transmission networks are usually run by a Regional Transmission Operator or Independent System Operator (RTO/ISO).

The Distribution Domain

The distribution domain serves as the intermediary between the transmission and customer domains and is normally connected in a radial configuration with customers and their metering systems. However, with the capabilities of the Smart Grid, the interaction of the distribution domain with the customer can also be a mesh or loop and through wired or wireless networks. This domain also will connect to energy storage facilities.

The Operations Domain

The operations domain provides reliable and high-quality power delivery on the Grid and interacts with all other domains of the Grid. Historically, operations have been the responsibility of a regulated utility, but they can also be the function of a service provider. This domain provides for locating faults, monitoring equipment, such as breakers and switches, evaluating security, keeping inventory, scheduling maintenance, monitoring intelligent

field devices, gathering business intelligence, and optimizing Grid performance.

The Service Provider Domain

The service provider domain communicates with the operations domain, if they are separate entities, to provide the basis for controlling critical elements of the Grid. It also interacts with the markets and customer domains to provide account management and billing. Additional functions performed by the service provider domain include:

- Handling customer problems
- Maintenance and installation of customer premises devices
- Managing business accounts
- Providing building and home energy management

The Markets Domain

The markets domain buys and sells energy services and communicates with the other domains to balance supply and demand. Additional functions provided by this domain include:

- Establishing pricing mechanisms
- Managing regulation issues
- Providing roaming billing information
- Providing secure communication with other domains
- Supporting interoperability across suppliers of market data

The Customer Domain

The customer domain is where the electricity is used and where customers can manage their electricity usage and electricity generation if applicable. A customer might be a home user, an industrial plant, or a building. In addition to the meter, the customer domain interacts with the utility through the Energy Services Interface (ESI), which might communicate with additional domains through the Advanced Metering Infrastructure (AMI). A customer might also generate and store energy for transmission back into the Grid.

Advanced Metering Infrastructure

An important subsystem of the Smart Grid that is part of the customer domain in [Figure 4-1](#) is the AMI. The AMI comprises hardware and meter data management (MDM) software that provide the normal meter reading functions and support two-way communications that can exchange energy information and commands with customers' devices through a home area network. The AMI can be used to implement dynamic electricity pricing and load management, including voluntary programs where a customer can schedule load reductions with prior notice in return for pricing reductions. There are analogous networks that apply to the industrial customer.

In addition to the smart meter, another critical component of the AMI is the ESI, which acts as a gateway to the customer's network. While the smart meter provides functions, such as determining and communicating energy usage, connecting or disconnecting service, measuring the amount of power fed into the grid from distributed power sources, and communicating with the home area network or equivalent, the ESI serves as the connection to the energy service provider. The service provider is usually a utility, but it can also be a third party that provides energy management services to the customer.

Some of the functions that can be supported by the AMI include:

- Providing the ability of external, third-party clients to communicate with and control customer devices to allow customers to take part in load reduction options
- Supporting voluntary load reduction at the customer's location by providing the customer with instantaneous kWhr electricity pricing
- Measuring the effectiveness of the voluntary load reduction incentives to the customer
- Optimizing building loads through building automation systems for large customers

- Providing the ability to detect, map, and restore outages to the customer

NIST⁶ identifies the following Smart Grid elements as participating in the AMI:

- Regional Transmission Organization (RTO) – An independent organization that coordinates, controls, and monitors the operation of the electrical power system and supply in a particular geographic area; similar to Independent System Operator
- Independent System Operator (ISO) – An independent entity that controls a power grid to coordinate the generation and transmission of electricity and ensure a reliable power supply

- Energy Market Clearinghouse – Wide-area energy market operation system providing high-level market signals for operations
- Service Provider – A person or company combining two or more customers into a single purchasing unit to negotiate the purchase of electricity from retail electric providers or the sale of electricity to these entities; providing consolidated bills to customers
- Utility Energy Management Systems (EMS) – The entities that continue to provide regulated services for the distribution of electricity (and gas and water) to customers and to serve customers that do not choose direct access. Regardless of where a customer chooses to purchase power, the customer's current utility will deliver the power to the customer's home or business.
- Operations – Calculation and analysis of power flow/state estimation results with the inclusion of distribution automation capabilities, demand response signaling, distributed energy resources, electric storage, PEVs (plug-in electric vehicles), and load management; provide a Web site to enable customer access to usage and billing records
- Meter Data Management System (MDMS) – System providing meter data validation and verification so that reliable information can be used at bill settlement

- Metering System – The system used for collecting metering information
- Load Management System (LMS) – Controlling demand responses (DR), distributed energy resources (DER), plug-in electric vehicles (PEV), energy storage (ES) charging/discharging, processing and storing data on load management programs, storing information on contracts and relevant historic information, creating behavioral models, collecting, processing, and storing customer-specific power quality and reliability characteristics, and so on.
- Customer Information System (CIS) – Repository of customer information related to distribution company services. CIS contains load data for customers that are estimated for each nodal location on a feeder, based on billing data and time-of-day and day-of-week load shapes for different load categories.
- SCADA – SCADA database is updated via remote monitoring and operator inputs. Required scope, speed, and accuracy of real-time measurements are provided; supervisory and closed-loop control is supported.

- Field Devices – Field equipment with local intelligence for monitoring and control of automated devices in the distribution, which communicates with SCADA as well as distributed intelligence capabilities for automatic operations in a localized distribution area based on local information and on data exchange between members of the group.
- Meter – Unless otherwise qualified, a device of the utility used in measuring watts, vars, var-hours, volt-amperes, or volt-ampere-hours. Var stands for volt-ampere reactive power, which is the power in an AC circuit where there is a capacitive or inductive load.
- Energy Services Interface (ESI) – Provides cybersecurity and (often) coordination functions that enable secure interactions between relevant home area network devices and the utility. Permits applications such as remote load control, monitoring and control of distributed generation, in-home display of customer usage, reading of nonenergy meters, and integration with building management

systems. Provides auditing/logging functions that record transactions to and from home area networking devices. Can also act as a gateway.

- Customer EMS – Customer energy management system that can receive pricing and other signals for managing customer devices, including appliances, DER, electric storage, and PEVs.
- Customer Appliances, DER, PEV, and Electric Storage – Equipment and systems at the customer site that could participate in demand response and other programs
- Submeter – A meter that measures a subload, such as a plug-in electric vehicle.

Energy Storage and Management of Stored Energy

Energy storage (ES) is an important element of the Smart Grid concept. It can support the use of intermittent renewable energy devices and energy storage devices at the generating site, as well as allow for the use of electricity generated at a customer site. The connection of ES devices to the Grid must be done according to specified standards and guidelines to ensure the safe and efficient connection of external generation and storage devices to the Grid. These standards and guidelines have to address the following issues:

- Accommodation of intermittent renewable energy sources by storage of energy generated
- Effective deployment of ES-distributed energy resource (DER) systems
- ES-DER transmission implementations
- Interfaces to rotating machines
- Interoperability among ES-DER systems
- Modification of existing standards such as IEEE 1547⁷ to address various types of ES-DER systems and the DER connections with the Grid
- New Smart Grid storage and power electronics technologies

There are quite a few energy storage technologies being developed and/or improved that can be used in the Smart Grid architecture. Some of the more promising approaches are:

- Compressed Air – Energy is stored by pumping compressed air into a storage container or underground cavity and then releasing it when needed to power a turbine that generates electricity. An advantage is that it is a well-known technology, but a disadvantage is that it does impact the environment and requires a lengthy approval process. Compressed-air projects are used in large utility applications, but can be used in smaller applications.
- Flywheels – Energy is stored in large, high-mass, rapidly rotating discs, which can impart energy to generators to provide back-up or storage power and also support frequency regulation.
- Fuel Cells – Fuel cells produce electricity through conversion of chemical energy. A fuel cell requires a fuel supply and an oxidizing agent. A hydrogen fuel cell uses hydrogen as the fuel and oxygen as an oxidizer. Fuel cells can rapidly recharge.

- Lithium-ion Batteries – Modern technology battery with higher charging rates and higher energy densities than lead acid batteries. Development is focused on the automotive and electrical grid markets. These batteries have fast response and are best used at the generation project level.
- Pumped Hydro – Water is pumped from a lower-level storage basin to one at a higher level. Electricity can then be generated at a later time by having the water flow downhill through a turbine to generate electricity. This technology is used for centralized, utility-scale projects and is able to handle load with quick response.
- Sodium Sulfur Batteries – Batteries using sodium and liquid sulfur. These batteries are more efficient in larger sizes but have to be properly sealed and protected from water as sodium spontaneously explodes when it comes in contact with water.
- Ultracapacitors – Large amounts of electrical charge can be stored on new technology capacitors and then tapped when energy is needed. Capacitors typically have short charging times and provide high quantities of energy when discharged.

Smart Grid Protocols

The Smart Grid is a system of systems with two types of flow: power and communications. For data to be exchanged among all the domains of the Smart Grid, standard protocols must be used. There are a number of viable candidate protocols, each with its own advantages and disadvantages. One major candidate protocol is the Internet Protocol (IP), which was discussed in [Chapter 1](#).

IP was originally designed to allow dissimilar networks to communicate with each other and to provide flexibility in the types of physical connections used. It is widely deployed and has a base of support tools and security mechanisms. IP and the Internet protocols provide the advantages of interoperability with other applications that have been developed and deployed over the years relating to the Internet.

To be effective in the Smart Grid, a protocol must meet the requirements of different domains of the Grid. For example, in the AMI, data collection does not have to be instantaneous and data can be collected every 15 or 20 minutes. Conversely, in the bulk generation facilities, operations have to be performed on the order of milliseconds. Thus, IP would be a good fit for the Smart Grid in general, but where deterministic elements are involved, other protocols more appropriate to control systems should be employed.

An additional standard that has been developed for interfacing to data communication networks, such as used in the Smart Grid, is defined in ANSI C12.22-2008⁷. ANSI C12.22 specifies a protocol for communicating with devices, such as data modules and meters. It provides security through the use of AES encryption methods. For Smart Grid purposes, ANSI C12.22 is an improvement over previous standards C12.18 and C12.21, which addressed meter reading through optical ports and modems, respectively, which are more suited to high-volume commercial and industrial customers. ANSI C12.22 is more appropriate for reading residential meters than C12.18 and C12.21. The main features of C12.22 are

a protocol for the data link, physical layers for meter communications, and an application level protocol that is independent of the transport method used.

Another important protocol suite that is widely used in Europe in conjunction with smart meters is the IEC 62056-XX series. It is based on the Device Language Message Specification (DLMS)/COmpanion Specification for Energy Metering (COSEM) suite. DLMS uses the abstract modeling of communication elements, and COSEM establishes rules for smart meter data exchanges. DLMS/COSEM provides interoperability among a variety of meters and other modules. The components of the IEC 62056 series are summarized as follows:

- IEC 62056-21 – Defines data communications through electrical and optical ports
- IEC 62056-31 – Provides guidance on the use of local area networks on twisted pair
- IEC/TS 62056-41 – Addresses data communications over wide area networks
- IEC 62056-42 – Addresses physical layer services for asynchronous data interchanges
- IEC 62056-46 – Covers the High Level Data Link Control (HDLC) protocol for use in the data link layer
- IEC 62056-47 – Focuses on the COSEM IPv4 transport layer and communications from the application layer

- IEC/TS 62056-51 – Addresses protocols in the application layer
- IEC/TS 62056-52 – Discusses protocols for the management distribution line message specification (DLMS) server
- IEC 62056-53 – Provides guidance on establishing application associations among peer applications and messaging services
- IEC 62056-61 – Supports data identification for various types of data, including abstract data
- IEC 62056-62 – Defines the COSEM interface classes for modeling the range of meter functions

Mapping of Emerging Technology Issues onto an Example Automation System – The Smart Grid

The technologies associated with home area networks, energy storage, analytics, cloud computing, privacy, social networks, mobile technology, and interoperability will have a significant impact on industrial automation and control systems. [Figure 4-2](#) summarizes the domains of the Smart Grid that will be most affected by these technologies.

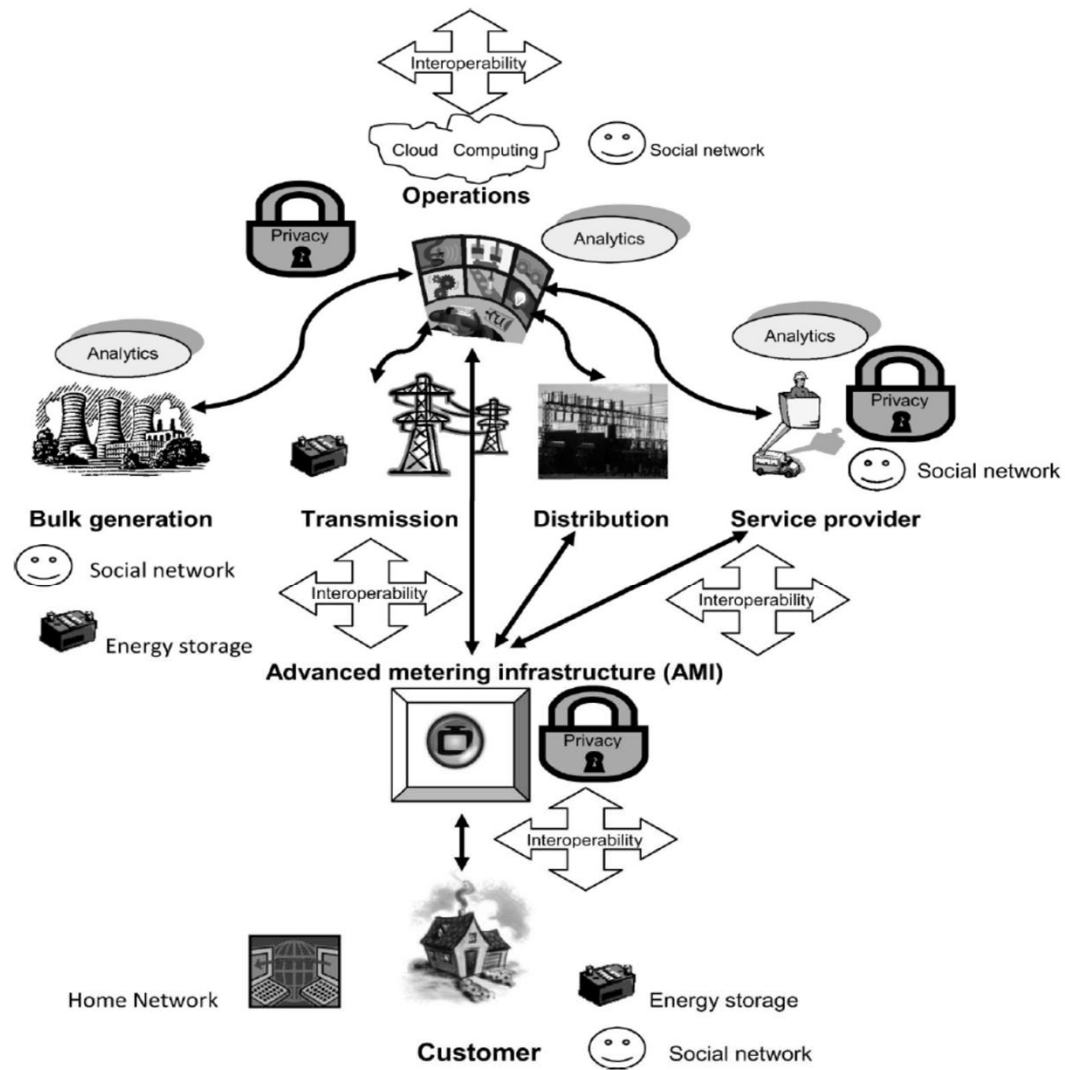


Figure 4-2. Smart Grid domains

To recap the earlier discussion:

Applying analytics in bulk generation can lead to improved and more efficient maintenance strategies by alerting operators before outages occur. In addition, the information obtained from applying analytics can lead to significant reductions in fuel costs, thus increasing profitability. Bulk generation facilities also require efficient and cost-effective energy storage, particularly for intermittent renewable energy sources, such as wind farms and solar collectors.

Social networking by operators with other domains can improve cooperation and understanding; however, it also holds the potential for compromise of sensitive information.

The transmission domain must maintain close communications with the operations domain and provide energy management and storage as needed. The distribution domain must also communicate with the operations domain and effectively provide electricity to the customer.

The service provider domain handles large amounts of customer personally identifiable information and must ensure that adequate privacy protections are in place. Social networking used in this environment offers benefits but might also be a source of security and privacy breaches.

The operations domain must communicate effectively with the other domains and provide efficient and reliable power management. In performing its functions, the operations domain can apply analytics to provide insight into potential problem areas before they become critical and can be used to initiate proactive solutions instead of reacting to system failures. With the large amount of data being gathered by the operations domain, cloud computing can offer significant value and savings by making on-demand applications and computing capacity available as needed. However, because social networking might also be involved in this domain, privacy protections have to be adequately implemented.

The AMI is a critical link to the customer domain and must ensure efficient transfer of information and offer privacy protections for PII.

The customer domain is the focus of all the other domains and can be a source or sink of electricity. It also provides communications with home area networks and smart meters to implement dynamic pricing and customer opt-in for energy savings. The customer domain, as a source of electricity to the Grid, can have energy storage capacity for intermittent sources of electricity. The customer domain can also have the highest volume of social networking and can thus be a source of compromise and loss of sensitive information.

All the domains must have high degrees of interoperability or the benefits of the Smart Grid will be significantly reduced.

Summary

Technological advancements pose a Cornelian dilemma in that choosing to use them or not to use them can both yield negative consequences. However, in most instances, the benefits of using them outweigh the risks. The key is to apply the new technologies in an intelligent and effective manner while implementing protections against the vulnerabilities introduced by these advancements.

Home area networks, energy storage, analytics, cloud computing, privacy, social networks, mobile technology, and interoperability can provide significant improvements in the performance, safety, security, and cost-effectiveness of industrial automation and control systems, if appropriate safeguards are employed.

Chapter 4 will explore the threats and risks to industrial automation and control systems and provide methods to quantify, evaluate, and manage the risks.

